

Web Security Audit

Formal Security Report

Production Web Infrastructure — Comprehensive Findings & Remediation Plan

■ **CONFIDENTIAL — INTERNAL USE ONLY** ■

Date:	May 7, 2026
Version:	1.0 DRAFT
Prepared By:	Security Engineering Team
Classification:	CONFIDENTIAL
Total Findings:	6 (2 HIGH, 3 MEDIUM, 0 LOW)
Report Status:	Open — Remediation In Progress

Distribution: Leadership | sec-eng | edge | platform | frontend | telemetry | sre | qa | compliance

*This document contains sensitive security findings. Unauthorized disclosure is prohibited.
Handle in accordance with the organization's Information Classification Policy.*

Table of Contents

Section 1 — Executive Cover Note

Section 2 — Audit Scope and Methodology

Section 3 — Findings Summary Table

Section 4 — Detailed Findings

SEC-001 — Inconsistent WAF Response Codes (403 vs 200)

SEC-002 — Telemetry Ingestion of Malformed URLs

SEC-003 — Quirks Mode Rendering on Error Pages

SEC-004 — Missing Subresource Integrity (SRI)

SEC-005 — Cookie Persistence / Session Management

SEC-006 — Analytics Beacon Data Exposure

Section 5 — Compliance Mapping Table

Section 6 — Risk Register

Section 7 — Appendices

Appendix A — Glossary of Terms

Appendix B — Evidence File Index

Appendix C — Remediation Team Contacts

Appendix D — Document Control

Section 1: Executive Cover Note

TO: Executive Leadership

FROM: Security Engineering

DATE: May 7, 2026

RE: Web Security Audit — Remediation Action Required



IMMEDIATE ACTION REQUIRED — HIGH SEVERITY FINDINGS

Two findings rated HIGH severity require executive escalation and engineering action within 24 hours of this report's issuance. See Section 3 for owner assignments and priority timelines.

The Security Engineering team has completed a comprehensive web security audit of the organization's production web infrastructure, encompassing the edge and WAF layer, frontend rendering pipeline, telemetry ingestion system, cookie and session management controls, and third-party asset integrity configuration. The audit identified **six (6) discrete security findings** spanning WAF configuration integrity, telemetry ingestion validation, browser rendering behaviors, subresource integrity enforcement, cookie security attributes, and analytics beacon data exposure. These findings collectively represent meaningful gaps in our defense-in-depth posture and require coordinated, time-bound remediation across multiple engineering teams.

Of the six findings, **two are rated HIGH severity** — SEC-001 (Inconsistent WAF Responses: 403 vs 200) and SEC-005 (Cookie Persistence / Session Management) — with a combined CVSS score range of 7.5–7.8. These findings expose active bypass vectors in our WAF rule enforcement and session security controls and must be addressed within **24 hours** of this report's issuance. SEC-002 (Telemetry Ingestion of Malformed URLs, CVSS 7.1) is similarly rated HIGH and shares the same 24-hour remediation window. Each finding in this report carries a fully assigned owner team, a documented remediation plan with numbered action steps, defined verification criteria, and rollback procedures to protect production stability during remediation.

The Security Engineering team respectfully requests **executive sponsorship for a dedicated cross-team remediation sprint** beginning immediately. Sponsor support is needed to authorize temporary capacity reallocation across the edge, platform, frontend, telemetry, sre, qa, and compliance teams; to establish a war-room cadence for the 24-hour HIGH-severity window; and to ensure compliance sign-off on data minimization actions for SEC-006 prior to the June 6, 2026 target date. All findings, evidence, compliance mappings, and risk register entries are detailed in the sections that follow. The Security Engineering team is available for briefing at any time.

Section 2: Audit Scope and Methodology

2.1 Audit Scope

This audit covered the following components of the organization's production web infrastructure:

- **Edge / WAF Layer:** Web Application Firewall rule sets, managed rule groups, custom rule priority ordering, and response code normalization
- **Frontend:** HTML rendering context, DOCTYPE configuration, third-party and CDN-hosted asset loading, subresource integrity enforcement, Content Security Policy implementation
- **Telemetry Pipeline:** Beacon ingestion endpoints, URL and payload validation, schema enforcement, fast-path processing controls
- **Cookie and Session Management:** Cookie attribute configuration (Secure, HttpOnly, SameSite), session token persistence duration, and privilege escalation handling
- **CSP / SRI Configuration:** Content Security Policy headers on all page types including error pages; Subresource Integrity hash presence on all external script and stylesheet assets
- **Analytics Telemetry:** Beacon payload field contents, PII exposure in transmitted URLs, transport protocol enforcement, and compliance with data minimization requirements

2.2 Methodology

The following techniques and inspection methods were applied during this audit:

- **HTTP Traffic Analysis:** Full inspection of GET and POST request/response logs, WAF response classification, status code comparison across equivalent request patterns
- **Browser Console Inspection:** Frame capture and rendering context analysis using browser developer tools; DOM compatibility mode inspection; CSP enforcement verification
- **WAF Response Auditing:** Comparison of blocked vs. passed requests across OWASP CRS rule categories including XSS, path traversal, and injection; false-negative rate analysis
- **Telemetry Pipeline Review:** Analysis of beacon POST payloads, referrer URL field contents, schema validation bypass conditions, and cross-domain beacon firing behavior
- **Static Asset Integrity Verification:** Enumeration of all external script and stylesheet tags in production HTML; integrity attribute presence check; crossorigin attribute audit
- **Cookie Attribute Inspection:** Set-Cookie header analysis across authenticated and unauthenticated sessions; Max-Age, Secure, HttpOnly, and SameSite attribute validation

2.3 Evidence Collected

Evidence File	Type	Description	Used In Finding(s)
GET.txt	HTTP Request Log	GET request log showing WAF response codes including misclassified 200 OK responses on blocked-pattern queries	SEC-001
bscframe.html	Browser Session Frame Capture	Browser session DOM capture confirming Quirks Mode rendering,	SEC-001, SEC-003, SEC-004, SEC-005

Evidence File	Type	Description	Used In Finding(s)
		missing SRI attributes, and cookie header analysis	
00_04_56.233	Network Timing Log	Timestamped telemetry beacon payload captures including malformed referrer URLs and schema validation bypass events	SEC-002, SEC-006
bing-traffic-capture.txt	Cross-Domain Traffic Capture	Bing search traffic showing cross-domain beacon firing with unsanitized query parameters transmitted to analytics endpoints	SEC-002, SEC-006

2.4 Testing Period

May 2026. All evidence was collected within the production environment during active traffic conditions. No synthetic or simulated traffic was used as a primary evidence source. Testing was conducted under authorized security audit scope.

2.5 Standards Referenced

- **OWASP Top 10 2021** — Primary application security classification framework
- **CWE/SANS Top 25** — Common Weakness Enumeration reference for vulnerability categorization
- **PCI-DSS v4.0** — Payment Card Industry Data Security Standard, applicable requirements cross-referenced per finding
- **NIST SP 800-53 Rev. 5** — Security and Privacy Controls for Information Systems and Organizations

- **GDPR Article 5 / CCPA §1798** — Data minimization and personal information protection obligations

Section 3: Findings Summary Table

 Reading This Table

Severity ratings follow CVSS v3.1 scoring. CRITICAL: 9.0–10.0 | HIGH: 7.0–8.9 | MEDIUM: 4.0–6.9 | LOW: 0.1–3.9. Priority Timeline indicates hours or days from report issuance date (May 7, 2026).

Finding ID	Title	Severity	CVSS Score	Owner Team(s)	Status	Priority Timeline
SEC-001	Inconsistent WAF Responses (403 vs 200)	HIGH	7.5	edge, sec-eng	Open	0-24h
SEC-002	Telemetry Ingestion of Malformed URLs	HIGH	7.1	telemetry, platform	Open	0-24h
SEC-003	Quirks Mode Rendering on Error Pages	MEDIUM	5.4	frontend, platform	Open	1-7d
SEC-004	Missing Subresource Integrity (SRI)	MEDIUM	5.8	frontend, sec-eng	Open	1-7d

Finding ID	Title	Severity	CVSS Score	Owner Team(s)	Status	Priority Timeline
SEC-005	Cookie Persistence / Session Management	HIGH	7.8	platform, sre	Open	0-24h
SEC-006	Analytics Beacon Data Exposure	MEDIUM	5.3	telemetry, compliance	Open	7-30d

Severity	Count	Findings	Recommended Action
HIGH	3	SEC-001, SEC-002, SEC-005	Immediate remediation — 0 to 24 hours
MEDIUM	3	SEC-003, SEC-004, SEC-006	Scheduled remediation — 1 to 30 days
LOW / INFO	0	—	—

Section 4: Detailed Findings

■ Finding SEC-001: Inconsistent WAF Response Codes (403 vs 200)

Severity:	HIGH	CVSS v3.1:	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Owner Teams:	edge, sec-eng	Priority:	0-24 Hours
CWE Reference:	CWE-693 — Protection Mechanism Failure		

Description

The Web Application Firewall returns inconsistent HTTP response codes for the same class of request patterns. Certain payloads that should be blocked with HTTP 403 are instead receiving HTTP 200 OK responses, indicating WAF rule gaps or bypass conditions. This allows potentially malicious requests to reach the origin server unfiltered, negating the protective function of the WAF layer and creating a false sense of security in monitoring dashboards that rely on 403 counts as a proxy for blocked attack volume.

Evidence

Captured in **GET.txt** — multiple requests with suspicious query parameters returned 200 OK where WAF block rules should have triggered 403. Response body analysis from **bscframe.html** confirms origin server responses on some blocked-pattern requests, indicating the requests reached the application tier.

Evidence Excerpt (from GET.txt log):

```
GET /search?q=
```

```
<
```

```
script
```

```
>
```

```
alert(1)
```

```
<
```

```
/script
```

```
>
```

```
HTTP/1.1 → 200 OK [WAF MISS] GET /search?q=../../../../etc/passwd HTTP/1.1
```

```
→ 403 Forbidden [WAF BLOCK] GET /search?q=%3Cscript%3E HTTP/1.1
```

```
→ 200 OK [WAF MISS - encoded variant]
```

Impact

Attackers can probe WAF rule gaps to identify bypass vectors by comparing response codes across URL-encoded and plaintext payloads. Inconsistent enforcement creates a false sense of security in monitoring dashboards relying on 403 counts as blocked-attack telemetry. Successful bypass allows XSS, path traversal, and injection payloads to reach origin servers.

Remediation Steps

1. Audit all WAF rule sets — compare managed rules vs. custom rule priority ordering for conflicts or shadow rules
2. Enable paranoia level escalation for XSS and path traversal rule groups to enforce detection on encoded variants
3. Implement WAF logging for ALL requests (not just blocked ones) to establish a false-negative baseline rate
4. Deploy unified response normalization: all blocked requests MUST return 403 with no body, regardless of rule match source
5. Add WAF bypass detection alerting in SIEM with correlation rules for 200 responses on known-bad pattern classes

Verification Steps

Run the WAF test suite (`sec-eng/waf-test-harness`) against all rule groups. Confirm 0% false-negative rate for OWASP CRS rules. Verify SIEM alerts trigger within 60 seconds of test block events. Confirm response normalization: all blocked requests return HTTP 403 with no response body.

Rollback Criteria

If WAF rule escalation causes >0.5% false-positive rate on production traffic (measured over a 1-hour observation window), revert paranoia level to prior setting and re-evaluate rule specificity before re-escalating. Document false-positive categories in a JIRA ticket assigned to sec-eng.

Compliance Notes

PCI-DSS v4.0 Req 6.4 (WAF protection for public-facing web applications) | OWASP A05:2021 (Security Misconfiguration)

■ Finding SEC-002: Telemetry Ingestion of Malformed URLs

Severity:	HIGH	CVSS v3.1:	7.1 (AV:N/AC:L/PR:N/UI: R/S:U/C:H/I:L/A:N)
Owner Teams:	telemetry, platform	Priority:	0-24 Hours
CWE Reference:	CWE-20 — Improper Input Validation		

Description

The telemetry ingestion pipeline accepts and processes malformed or adversarially crafted URLs without sanitization or schema validation. Captured traffic shows beacon requests containing URLs with embedded null bytes, oversized query strings, and protocol-relative URL fragments that bypass standard URL parsers. A fast-path processing mode has been identified that explicitly skips schema validation, compounding the exposure. This creates risk of log injection, SSRF via forwarded telemetry, and downstream analytics data corruption.

Evidence

Network timing log (**00_04_56.233**) shows telemetry beacon payloads with malformed referrer URLs including `javascript:` protocol URIs and null-byte sequences. Bing traffic capture confirms cross-domain beacon firing with unsanitized query parameters transmitted to analytics endpoints.

Evidence Excerpt (from 00_04_56.233 log):

```
[00:04:56.233] BEACON POST /collect → payload.url = "//evil.example.com/\n\nx00track" [00:04:56.891] BEACON POST /collect → payload.referrer =\n\n"javascript:void(alert(1))" [00:04:57.102] TELEMETRY INGEST →\n\nschema_validation: SKIPPED (fast path)
```

Impact

Malformed URL injection can corrupt analytics dashboards, enable log injection attacks that falsify audit trails, and in the worst case facilitate Server-Side Request Forgery (SSRF) through telemetry forwarding pipelines that resolve or re-request URL field values internally. The fast-path bypass is a critical aggravating factor.

Remediation Steps

6. Implement strict URL schema validation on all telemetry ingestion endpoints — allowlist: `https://` and `http://` only
7. Reject and log all payloads containing null bytes (`\x00`), `javascript:` protocol, or protocol-relative URLs (`//` prefix without scheme)
8. Enforce maximum URL length of 2048 characters at the ingestion boundary; reject with HTTP 400 on excess
9. Add input sanitization middleware before fast-path processing — fast path must not bypass validation
10. Deploy anomaly alerting for malformed payload rates exceeding 1% of total beacon volume per 5-minute window

Verification Steps

Submit test payloads with `javascript:` URLs, null bytes, and protocol-relative URLs to `/collect`. Confirm all are rejected with HTTP 400. Verify rejection events appear in SIEM within 30 seconds. Confirm fast-path code path is covered by validation middleware unit tests.

Rollback Criteria

If malformed URL rejection causes >2% drop in legitimate telemetry volume (measured against 24-hour baseline), relax the null-byte filter pattern and re-evaluate regex specificity. Do not disable schema validation wholesale — investigate the specific pattern causing regression and adjust the allowlist accordingly.

Compliance Notes

OWASP A03:2021 (Injection) | NIST SP 800-53 SI-10 (Information Input Validation)
| PCI-DSS v4.0 Req 6.2

■ Finding SEC-003: Quirks Mode Rendering on Error Pages

Severity:	MEDIUM	CVSS v3.1:	5.4 (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)
Owner Teams:	frontend, platform	Priority:	1-7 Days
CWE Reference:	CWE-116 — Improper Encoding or Escaping of Output		

Description

Custom error pages (4xx/5xx) are served without a DOCTYPE declaration, or with a malformed DOCTYPE, causing modern browsers to render them in Quirks Mode. Browser console evidence from **bscframe.html** confirms the rendering context. Quirks Mode disables modern security behaviors including stricter XSS filtering heuristics in legacy browsers, breaks Content Security Policy enforcement in some browser versions, and can expose error pages to clickjacking through legacy layout behaviors not present in Standards Mode.

Evidence

The **bscframe.html** capture shows the error page rendered in Quirks Mode, confirmed via `document.compatMode === "BackCompat"`. Console trace shows a CSP meta tag being ignored due to the quirks rendering context, indicating that meta-tag-based CSP enforcement is silently failing on all affected error page responses.

Remediation Steps

11. Add `<!DOCTYPE html>` as the absolute first line of ALL error page templates: `40x.html`, `50x.html`, and any dynamically generated error responses
12. Validate DOCTYPE presence in CI/CD pipeline HTML linting step — fail build on missing or malformed DOCTYPE in any template file
13. Add `X-Content-Type-Options: nosniff` header to all error page HTTP responses

14. Review all server-side error template generators (Nginx, application-layer error handlers) for DOCTYPE injection or stripping behavior

Verification Steps

Load `/error/404` and `/error/500` in browser developer tools. Confirm `document.compatMode === "CSS1Compat"` (Standards Mode). Confirm `X-Content-Type-Options: nosniff` header is present in the HTTP response for all error page status codes.

Rollback Criteria

If DOCTYPE addition breaks legacy IE11 error page styling — which is unlikely given the deprecation of IE11 — maintain the DOCTYPE and fix CSS specificity issues instead. Under no circumstances should the DOCTYPE be removed as a rollback measure; CSS issues are always preferable to Quirks Mode operation.

Compliance Notes

OWASP A05:2021 (Security Misconfiguration) | CWE-116 | NIST SP 800-53 SI-2

■ Finding SEC-004: Missing Subresource Integrity (SRI)

Severity:	MEDIUM	CVSS v3.1:	5.8 (AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:L/A:N)
Owner Teams:	frontend, sec-eng	Priority:	1–7 Days
CWE Reference:	CWE-353 — Missing Support for Integrity Check		

Description

Multiple third-party and CDN-hosted JavaScript and CSS assets are loaded without Subresource Integrity (SRI) hash attributes. If a CDN is compromised or an asset is tampered with in transit, browsers will load and execute the malicious content with no integrity validation — a supply chain attack vector. Evidence from **bscframe.html** shows script and link tags loading analytics, tracking, and UI library assets from external CDNs with no `integrity` or `crossorigin` attributes present.

Evidence

Evidence Excerpt (from bscframe.html):

```
<
!-- NO SRI - VULNERABLE --
>
<
script src="https://cdn.example.com/analytics.js"
>
<
/script
>
<
link rel="stylesheet" href="https://cdn.example.com/ui-lib.css"
>
<
!-- CORRECT - WITH SRI --
>
<
script src="https://cdn.example.com/analytics.js"    integrity="sha384-[HASH]"
crossorigin="anonymous"
>
<
```

```
/script
```

```
>
```

Remediation Steps

15. Run SRI drift detection script (see `patch-snippets.txt`) to enumerate all external assets currently loaded without SRI attributes
16. Generate SHA-384 hashes for all identified external assets using the `sri-hash-generator` tooling maintained by sec-eng
17. Add `integrity="sha384-[HASH]"` and `crossorigin="anonymous"` attributes to all identified `<script>` and `<link>` tags
18. Add a CI/CD check that blocks merge if any new external assets are added to HTML templates without an SRI `integrity` attribute
19. Implement weekly SRI drift monitoring via automated pipeline to detect CDN asset changes that would invalidate existing hashes

Verification Steps

Run `sri-audit.sh` against production HTML output. Confirm 0 external assets without SRI attribute. Verify browser developer tools shows "integrity check passed" for all external resources. Confirm CI/CD SRI gate blocks a test PR containing an asset tag without an integrity attribute.

Rollback Criteria

If an SRI hash mismatch blocks loading of a legitimately updated CDN asset, update the hash immediately — do not remove the SRI attribute. The `--no-sri-flag` temporary bypass is permitted only with written sec-eng approval documented in a JIRA ticket and must be reverted within 4 hours of the hash being updated.

Compliance Notes

OWASP A08:2021 (Software and Data Integrity Failures) | PCI-DSS v4.0 Req 6.4.3 | NIST SP 800-53 SA-12, SI-7

■ Finding SEC-005: Cookie Persistence / Session Management

Severity:	HIGH	CVSS v3.1:	7.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
Owner Teams:	platform, sre	Priority:	0-24 Hours
CWE Reference:	CWE-539 — Use of Persistent Cookies Containing Sensitive Information		

Description

Session and authentication cookies are configured with excessive persistence (Max-Age >30 days) and are missing critical security attributes. Evidence from browser session captures shows production cookies lacking the `Secure` flag, `HttpOnly` flag, and `SameSite=Strict` attribute. The absence of `HttpOnly` exposes session tokens to JavaScript-based theft via XSS; the absence of `Secure` allows transmission over unencrypted channels; and the 30-day Max-Age dramatically extends the session hijacking window and increases risk on shared or public devices.

Evidence

bscframe.html cookie headers show the following production Set-Cookie response:

```
Set-Cookie: session_id=[TOKEN]; Max-Age=2592000; Path=/    ↳ MISSING:
Secure    ↳ MISSING: HttpOnly    ↳ MISSING: SameSite
```

Remediation Steps

20. Reduce session cookie `Max-Age` to ≤ 3600 seconds (1 hour) with a server-side sliding window refresh mechanism to maintain usable sessions
21. Add the `Secure` flag to all session cookies — enforces HTTPS-only transmission
22. Add the `HttpOnly` flag to all session cookies — blocks JavaScript access via `document.cookie`

- 23. Add `SameSite=Strict` to session and authentication cookies; use `SameSite=Lax` for functional (non-authentication) cookies
- 24. Implement server-side session rotation on all privilege escalation events (login, role change, MFA completion)
- 25. Add cookie attribute validation to the deployment checklist and automated header scanning in staging QA

Verification Steps

Inspect `Set-Cookie` headers in browser developer tools on login and session refresh. Confirm all of the following are present: `Secure`, `HttpOnly`, `SameSite=Strict`. Confirm `Max-Age ≤ 3600`. Test that a cross-site forged request is rejected by the `SameSite` policy in the browser console.

Rollback Criteria

If `SameSite=Strict` breaks legitimate OAuth redirect flows (where the cookie must survive a cross-origin redirect), switch those specific cookies to `SameSite=Lax` and document the exception in the sec-eng runbook with a JIRA tracking ticket. Do not apply a blanket `SameSite=None` — require `Secure` on any `None` cookie.

Compliance Notes

OWASP A02:2021 (Cryptographic Failures) | PCI-DSS v4.0 Req 6.4 and 8.2 | NIST SP 800-53 IA-5, SC-8 | GDPR Article 32

■ Finding SEC-006: Analytics Beacon Data Exposure

Severity:	MEDIUM	CVSS v3.1:	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Owner Teams:	telemetry, compliance	Priority:	7-30 Days
CWE Reference:	CWE-359 — Exposure of Private Personal Information to an Unauthorized Actor		

Description

Analytics beacon samples captured in the network timing log contain PII-adjacent fields including full URL paths with authenticated user session identifiers embedded in query parameters, search query strings that reveal user intent, and referrer URLs from internal application pages. In some environments, beacons are transmitted over plain HTTP. No data minimization is applied prior to beacon transmission to third-party analytics endpoints, creating both regulatory exposure under GDPR and CCPA and reputational risk if beacon traffic is observed by third parties.

Evidence

Captured beacon payloads in **00_04_56.233** show URL fields containing authenticated path segments (e.g., `/dashboard/user/[uid]/settings`) and user-identifying query parameters (e.g., `?uid=`, `?session=`) transmitted to third-party analytics collection endpoints. HTTP (non-TLS) beacons were also observed in the staging environment pipeline.

Remediation Steps

26. Implement PII scrubbing middleware in the telemetry pipeline prior to beacon transmission — strip all fields matching the PII classification matrix
27. Strip authenticated path segments (patterns matching `/user/{id}/`, `/account/{id}/`) and user-identifying query parameters (`uid=`, `session=`, `token=`) from beacon URL fields before dispatch
28. Enforce HTTPS-only for ALL analytics beacon endpoints — reject HTTP beacon transmission at the pipeline level
29. Conduct a formal GDPR/CCPA data minimization review of all beacon schema fields in collaboration with the compliance team, targeting the 30-day window
30. Add data classification tags (PII, PII-Adjacent, Non-PII) to all telemetry schema fields in the schema registry to guide ongoing minimization

Verification Steps

Capture live beacon traffic in browser developer tools Network tab after remediation deployment. Confirm no session tokens, user IDs, or PII-adjacent values appear in

any beacon payload field. Confirm all beacons use HTTPS (no `http://` beacon endpoints). Run compliance team sign-off review before closing this finding.

Rollback Criteria

This finding is additive in nature — PII scrubbing does not remove functionality. If beacon volume drops >5% following scrubbing deployment (indicating scrubbing regex is incorrectly matching and stripping required fields), investigate the specific scrubbing patterns and adjust without reverting the scrubbing layer entirely. Do not restore PII transmission as a rollback measure.

Compliance Notes

GDPR Article 5(1)(c) — Data Minimisation | CCPA §1798 | OWASP A02:2021 | NIST SP 800-53 AR-4, RA-2

Section 5: Compliance Mapping Table

The table below cross-references each finding against applicable security standards and regulatory frameworks. Teams are expected to validate compliance control closure alongside technical remediation.

Finding ID	Title	OWASP 2021	CWE	PCI-DSS v4.0	NIST SP 800-53	GDPR / CCPA
SEC-001	WAF Response Inconsistency	A05 — Security Misconfiguration	CWE-693	Req 6.4	SI-3, SC-7	N/A
SEC-002	Malformed URL Ingestion	A03 — Injection	CWE-20	Req 6.2	SI-10, AC-4	Art. 25
SEC-003	Quirks Mode Rendering	A05 — Security Misconfiguration	CWE-116	Req 6.2	SI-2	N/A
SEC-004	Missing SRI	A08 — Software and Data Integrity Failures	CWE-353	Req 6.4.3	SA-12, SI-7	N/A

Finding ID	Title	OWASP 2021	CWE	PCI-DSS v4.0	NIST SP 800-53	GDPR / CCPA
SEC-005	Cookie / Session Management	A02 — Cryptographic Failures	CWE-539	Req 6.4, 8.2	IA-5, SC-8	Art. 32
SEC-006	Analytics Beacon PII Exposure	A02 — Cryptographic Failures	CWE-359	Req 6.4	AR-4, RA-2	Art. 5(1)(c), CCPA §1798

Compliance Closure Note

Compliance control closure requires both (a) technical remediation verified by sec-eng and (b) formal sign-off from the compliance team. PCI-DSS findings additionally require QA to confirm during the next scheduled scan cycle. GDPR/CCPA-mapped findings (SEC-002, SEC-005, SEC-006) require compliance team co-sign before closing the JIRA ticket.

Section 6: Risk Register

The following risk register documents the residual risk profile for each finding, independent risk ownership, and target remediation dates. Residual risk reflects the risk posture assuming no remediation action is taken by the target date.

Risk ID	Finding	Likelihood	Impact	Residual Risk	Risk Owner	Target Date
R-001	SEC-001 — WAF Bypass	High	High	CRITICAL	sec-eng	May 8, 2026
R-002	SEC-002 — Telemetry	High	Medium	HIGH	telemetry	May 8, 2026

Risk ID	Finding	Likelihood	Impact	Residual Risk	Risk Owner	Target Date
	y Injection					
R-003	SEC-003 — Quirks Mode	Low	Medium	MEDIUM	frontend	May 14, 2026
R-004	SEC-004 — Missing SRI	Medium	High	HIGH	frontend	May 14, 2026
R-005	SEC-005 — Cookie Issues	High	High	CRITICAL	platform	May 8, 2026
R-006	SEC-006 — Beacon PII	Medium	Medium	MEDIUM	telemetry	June 6, 2026

6.1 Risk Escalation Thresholds

Any finding that remains Open past its Target Date is automatically escalated to the CISO and the relevant VP-level sponsor for the owner team. CRITICAL-rated residual risks (R-001, R-005) require daily status updates to the security engineering leads until closed. Risk register status is reviewed weekly by sec-eng and updated in the master tracking JIRA epic.

6.2 Risk Acceptance Policy

Risk acceptance (i.e., deliberate decision not to remediate within the stated window) requires written approval from the CISO and the relevant business owner, documented in the JIRA ticket with a formal risk acceptance rationale and a revised target date not to exceed 90 days. CRITICAL residual risks cannot be formally accepted without board-level notification under the current Information Security Policy.

Section 7: Appendices

Appendix A: Glossary of Terms

Term	Definition
WAF	Web Application Firewall — a security layer that monitors, filters, and blocks HTTP/HTTPS traffic between the internet and a web application based on defined rule sets.
SRI	Subresource Integrity — a browser security feature that validates external script or stylesheet assets against a cryptographic hash before execution or application, preventing tampered CDN assets from loading.
CSP	Content Security Policy — an HTTP response header (or meta tag) that controls which sources of content the browser is permitted to load, mitigating XSS and data injection risks.
CORS	Cross-Origin Resource Sharing — a browser mechanism that uses HTTP headers to allow or restrict web application cross-domain requests based on origin policy.
SIEM	Security Information and Event Management — a system that aggregates and correlates security event log data from multiple sources to detect, alert on, and investigate security incidents in near real time.
XSS	Cross-Site Scripting — an injection attack in which malicious scripts are embedded into web pages viewed by other users, enabling session theft, credential harvesting, and DOM manipulation.
SSRF	Server-Side Request Forgery — an attack in which an adversary causes the server to make HTTP requests to unintended internal or external resources, potentially accessing internal services or bypassing network controls.
PII	Personally Identifiable Information — any data that can be used to identify a specific individual, either directly (name, email, user ID) or in combination with other data points. Regulated under GDPR, CCPA, and other frameworks.

Term	Definition
CWE	Common Weakness Enumeration — a community-developed list of common software and hardware weakness types maintained by MITRE, used as a standard taxonomy for vulnerability classification.
CVSS	Common Vulnerability Scoring System — an open framework for communicating the characteristics and severity of software vulnerabilities using a numeric score (0.0–10.0) based on attack vector, complexity, privileges required, user interaction, and impact.
Quirks Mode	A browser rendering mode activated when an HTML document lacks a valid DOCTYPE declaration. In Quirks Mode, browsers apply legacy layout and parsing rules from the pre-standards era, disabling modern security behaviors and breaking CSP meta-tag enforcement in some implementations.

Appendix B: Evidence File Index

File Name	Type	Size / Format	Referenced In	Chain of Custody
GET.txt	HTTP Request Log	Plain text, line-delimited	SEC-001	Collected by sec-eng during production traffic audit, May 2026. Stored in secure evidence repository.
bscframe.html	Browser Session Frame Capture	HTML DOM snapshot	SEC-001, SEC-003, SEC-004, SEC-005	Browser developer tools frame export, captured during authenticated session testing. Hash-verified.
00_04_56.233	Network Timing Log	Timestamped log, millisecond precision	SEC-002, SEC-006	HAR-derived network log captured during telemetry pipeline review.

File Name	Type	Size / Format	Referenced In	Chain of Custody
				Original HAR file archived.
bing-traffic-capture.txt	Cross-Domain Traffic Capture	Plain text, request/response pairs	SEC-002, SEC-006	Captured via proxy intercept during cross-domain beacon analysis. Anonymized before storage.

Evidence Handling

All evidence files are stored in the secure sec-eng evidence repository with access controls limited to sec-eng and designated auditors. Files are immutable once collected. Any analysis copies must be tracked via the evidence tracking system. Do not distribute evidence files outside the authorized distribution list without CISO approval.

Appendix C: Remediation Team Contacts

Team	Responsibility in This Audit	Findings Owned	Escalation Point
sec-eng	Security Engineering — audit author, WAF rule remediation co-owner, SRI tooling owner, overall remediation coordination	SEC-001 (co), SEC-004 (co)	Security Engineering Lead
edge	Edge Infrastructure — WAF configuration, CDN-layer response normalization, paranoia level management	SEC-001 (co)	Edge Infrastructure Lead

Team	Responsibility in This Audit	Findings Owned	Escalation Point
platform	Platform Engineering — telemetry ingestion pipeline, cookie/session management, error page template infrastructure	SEC-002 (co), SEC-003 (co), SEC-005 (co)	Platform Engineering Lead
frontend	Frontend Engineering — HTML template management, error page DOCTYPE, SRI attribute implementation, CI/CD linting	SEC-003 (co), SEC-004 (co)	Frontend Engineering Lead
telemetry	Telemetry Engineering — beacon pipeline, malformed URL validation middleware, PII scrubbing implementation	SEC-002 (co), SEC-006 (co)	Telemetry Engineering Lead
sre	Site Reliability Engineering — session management deployment, production change management, rollback execution	SEC-005 (co)	SRE Lead
qa	Quality Assurance — verification testing for all findings post-remediation, WAF test harness execution, PCI scan cycle	All (verification)	QA Lead
compliance	Compliance — GDPR/CCPA data minimization review, formal compliance sign-off for SEC-002, SEC-005, SEC-006	SEC-006 (co)	Chief Compliance Officer

Appendix D: Document Control

Version	Date	Author	Status	Change Summary
1.0 DRAFT	May 7, 2026	Security Engineering Team	Draft — Pending Review	Initial document creation. All six findings documented with full remediation plans, compliance mappings, and risk register entries.
1.1	TBD	—	Pending	Post-review revision incorporating leadership and compliance feedback.
2.0	TBD	—	Pending	Final version with remediation status updates and finding closures.

Review Role	Name / Team	Review Date	Status
Author Review	Security Engineering Team	May 7, 2026	Complete
Technical Review	sec-eng, edge, platform leads	TBD	Pending
Compliance Review	Compliance Team	TBD	Pending
Executive Approval	Executive Leadership	TBD	Pending
CISO Sign-Off	CISO	TBD	Pending

 Document Classification Reminder

This document is classified

CONFIDENTIAL — INTERNAL USE ONLY

. It contains details of active, unmitigated security vulnerabilities in production infrastructure. Distribution is restricted to the named distribution list on the cover page. Do not forward, print for unsecured storage, or transmit via unencrypted channels. Report unauthorized access to sec-eng immediately.